PROJECT UDYAM DIGITAL · PRIVACY AND SECURITY NOTE

Privacy by design, aligned with the DPDP Act, 2023

Team Code Pioneers · Aryan Goel, Vansh
Delhi Technological University
YTL Hackathon 2026 · Enterprise Track A

Our rule: **collect only what verifying one order needs, use it for that purpose only, and keep as little as possible.** The AI advisor talks to the owner, but it never sees documents or identity numbers, and it never decides eligibility or price; our own code does.

1 Consent before any data

- Upload is locked until the owner ticks a plain-language consent screen in their language: *what we collect, why, how long, who sees it, your rights*.
- Consent is recorded with time and language, per order (one purpose: verifying this order, never marketing).

2 Data minimisation

- Only 4 documents: GST certificate, Udyam certificate, signatory ID, recent bill. A GSTIN lookup or DigiLocker can replace uploads.
- The only contact detail is a mobile number; chat warns: don't share Aadhaar, PAN or bank details.

3 The AI never sees personal data

- A GSTIN is looked up on our server and replaced by a token (status, name, city); Aadhaar-like numbers, PAN, mobiles and emails become [REDACTED] before text reaches the LLM.
- A guardrail checks every AI reply against the real plan; the API key stays on the server.

4 Documents stay in-house, then disappear

- OCR runs on our own server (Tesseract); images are held in memory, read once and discarded, never written to disk or sent to any outside service.
- We keep only check results (pass / fix / fail with reasons), with IDs masked.

5 Masked by default

- Mobile (98******10), GSTIN and Udyam numbers are masked in every API response, screen and log.
- Order tracking needs order number plus mobile; e-sign uses a one-time code sent to the owner's phone.

6 Staff access is limited and audited

- The back office needs a staff PIN (checked in constant time, rate-limited) and shows masked numbers.
- Revealing a full number to call a lead is a deliberate click, written to an audit log (who, which lead, when).

Data	Purpose	Where it lives	Retention (prototype)
Chat text	Recommend a bundle	Server memory (redacted); owner's browser tab	Deleted after 30 idle minutes; tab copy cleared on close
Chat summary	Funnel analytics, back office	Server file, no identifiers	Until the pilot ends
Document images	Verify the business	Server memory only	Discarded right after the check (seconds)
KYC results	Prove the order was verified	Order record, IDs masked	Life of the contract (telecom KYC rules)
Mobile number	SMS updates, callback, e-sign code	Order / callback record	Life of the order; shown masked

Before a real launch

- Live GSTN (via a GST Suvidha Provider), Udyam, DigiLocker and Aadhaar e-Sign (licensed ESP) with logged consent artefacts.
- Encrypted database (PostgreSQL, encryption at rest, TLS everywhere), secrets in a vault, role-based staff logins with 2FA.
- Self-serve "see, correct, delete my data" and consent withdrawal; integrate a DPDP Consent Manager.
- Breach response plan: notify the Data Protection Board and affected owners as the DPDP Rules require.
- Prefer an India-hosted model endpoint; the LLM only ever receives redacted text in any case.
- Periodic security testing and a data-retention job that enforces the table above automatically.